

|                  |       |           |
|------------------|-------|-----------|
| Muhammad Ibtisam | Tariq | 261265753 |
|                  |       |           |

Date: March 25<sup>th</sup>, 2026

## **NIST Cybersecurity Framework Implementation in the banking sector**

### **1. Introduction**

Cybersecurity has become a fundamental requirement in the banking sector. Financial institutions process highly sensitive customer data, including account details, transaction histories, and personal identification information. Due to the high value of this data, banks are frequent targets of cyberattacks such as phishing, ransomware, and insider threats.

The National Institute of Standards and Technology (NIST) Cybersecurity Framework provides a structured and widely adopted approach to managing cybersecurity risks. The framework is built on five core functions: Identify, Protect, Detect, Respond, and Recover (NIST, 2018). These functions collectively guide organizations in building a strong cybersecurity posture.

This report applies the NIST Cybersecurity Framework to a banking environment and integrates concepts learned across all course modules, including asset management, risk assessment, access control, incident response, and business continuity. Practical scenarios are used throughout to demonstrate how these concepts apply in real-world banking operations.

### **2. Identify Assets and Risks**

The Identify function focuses on understanding organizational assets and associated risks. In the banking sector, key assets include customer databases, online banking systems, ATM networks, internal communication platforms, and cloud infrastructure.

As discussed in Module 4, information assets must be classified based on sensitivity. For example, customer financial data is categorized as confidential or protected, while marketing materials are classified as public. Proper classification ensures that sensitive data receives appropriate protection.

Ownership of information is another critical aspect. Information owners are responsible for defining classification levels, while custodians implement controls to protect data. This separation of responsibilities ensures accountability within the organization.

Risk assessment, as covered in Module 3, involves identifying threats, vulnerabilities, and potential impacts. Common threats in banking include phishing attacks, malware, insider threats, and denial-of-service attacks. Vulnerabilities may include outdated systems, weak authentication mechanisms, or human error.

For instance, a phishing attack targeting bank employees can lead to unauthorized access to internal systems. If an employee unknowingly provides login credentials, attackers may gain access to customer accounts, resulting in financial loss and reputational damage.

By identifying assets and risks, banks can prioritize security measures and allocate resources effectively.

### **3. Protect Safeguarding Systems and Data**

The Protect function involves implementing safeguards to ensure the delivery of critical services. In banking, multiple layers of protection are required to address different types of threats.

Access control, discussed in Module 8, is one of the most critical controls. Banks use role-based access control (RBAC) and the principle of least privilege to ensure employees only have access to the information necessary for their roles. Multi-factor authentication (MFA) further enhances security by requiring additional verification steps.

Human resource security (Module 5) ensures that employees do not become a security risk. This includes conducting background checks, providing cybersecurity training, and enforcing strict onboarding and offboarding procedures.

For example, when an employee leaves the organization, their access to systems must be immediately revoked. Failure to do so may result in insider threats, where former employees misuse their access to steal sensitive information.

Physical security (Module 6) protects the organization's infrastructure. Banks implement surveillance systems, restricted access areas, and security personnel to safeguard facilities such as data centers and server rooms.

System and cloud security (Modules 9 and 10) involve secure system development, regular patching, and proper configuration of cloud environments. Misconfigured cloud storage is a common cause of data breaches.

Data Loss Prevention (DLP) technologies (Module 4) monitor and control data transfers to prevent unauthorized disclosure. For example, if an employee attempts to transfer sensitive customer data outside the organization, the system may block the action or alert security teams.

These layered controls align with the defense-in-depth strategy, ensuring that if one control fails, others remain in place to protect the system.

#### **4. Detect and Respond Managing Incidents**

The Detect and Respond functions focus on identifying and addressing cybersecurity incidents. Banks must continuously monitor their systems to detect unusual activities.

Detection mechanisms include Security Information and Event Management (SIEM) systems, intrusion detection systems, and log analysis tools. These systems analyze network activity and generate alerts when suspicious behavior is detected.

For example, if a customer account is accessed from multiple geographic locations within a short time frame, the system may flag this as suspicious activity.

Once an incident is detected, banks follow an incident response plan as outlined in Module 7. The process includes preparation, detection, containment, eradication, recovery, and post-incident analysis.

In a real-world scenario, if unauthorized access to a customer account is detected, the bank may immediately lock the account, investigate the incident, and notify the customer. This rapid response minimizes potential damage.

Effective incident response requires coordination between different teams, including IT, security, and management. Clear communication and predefined procedures are essential for handling incidents efficiently.

## **5. Restoring Operations**

The Recover function ensures that banking operations can be restored after a cybersecurity incident. Business continuity planning (Module 11) plays a key role in this process.

Banks implement disaster recovery strategies such as data backups, redundant systems, and failover mechanisms. These measures ensure that critical services remain available even during disruptions.

For example, if a ransomware attack encrypts banking systems, backups can be used to restore data without paying the ransom.

Recovery also involves analyzing the incident to identify lessons learned and improve future security measures. Continuous improvement is essential for maintaining resilience against evolving threats.

## **6. Compliance and Emerging Risks**

Compliance with regulatory standards is essential in the banking sector. Banks must adhere to regulations such as PCI DSS, which ensure the secure handling of payment card data.

Non-compliance can result in significant financial penalties and loss of customer trust. Therefore, banks must regularly audit their systems and ensure that security controls meet regulatory requirements.

Emerging technologies such as artificial intelligence (AI) are increasingly used in banking for fraud detection and customer analysis. While AI offers benefits, it also introduces new risks, including data manipulation and algorithmic bias.

As discussed in Module 13, proper governance and security controls are necessary to ensure that AI systems are used responsibly and securely.

## **7. Conclusion**

The NIST Cybersecurity Framework provides a comprehensive approach to managing cybersecurity risks in the banking sector. By following the Identify, Protect, Detect, Respond, and Recover functions, banks can build a strong and resilient security posture.

This report demonstrates how concepts from all course modules work together to protect banking systems. Effective cybersecurity is not just about technology; it involves people, processes, and policies working together to mitigate risks.

Ultimately, strong cybersecurity practices are essential for maintaining customer trust, ensuring regulatory compliance, and supporting the long-term success of financial institutions.

## **References**

National Institute of Standards and Technology. (2018). Framework for Improving Critical Infrastructure Cybersecurity. <https://www.nist.gov/cyberframework>